

VortexSec

Vulnerability Analysis Report Memory-Safety Vulnerabilities, CVE Reali e Contromisure

Andrea Fiorillo – Corso di Laurea in Ingegneria Informatica

Ottobre 2026

Disclaimer Etico e Legale

Questo documento ha finalità esclusivamente didattiche nell'ambito dello studio della sicurezza del software a basso livello. Tutti i CVE citati sono di pubblico dominio (NVD, MITRE, CISA KEV) e vengono riportati a scopo di analisi storica e didattica, senza fornire codice di exploitation funzionante. L'obiettivo è comprendere la causa radice di ciascuna classe di vulnerabilità per poterla prevenire in fase di sviluppo.

Sommario

Questo report analizza quattro classi di vulnerabilità memory-safety rientranti nella CWE Top 25 (*Buffer Overflow*, *Use-After-Free*, *Integer Overflow*, *Format String*), per ciascuna delle quali viene presentata: la causa radice a livello di codice C/C++, un caso di studio reale documentato tramite CVE ufficiale, le famiglie di malware o ransomware che lo hanno sfruttato in-the-wild, e le contromisure applicabili in fase di sviluppo. Il documento si chiude con un'analisi architetturale dello schema di cifratura ibrida AES/RSA tipicamente impiegato dai ransomware moderni.

Indice

1	Metodologia	3
2	CWE-787 / CWE-121 / CWE-122 – Buffer Overflow	3
2.1	Causa Radice	3
2.2	Caso di Studio: CVE-2017-0144 (EternalBlue)	3
2.3	Malware e Ransomware Associati	4
3	CWE-416 – Use-After-Free	4
3.1	Causa Radice	4
3.2	Caso di Studio: CVE-2019-0708 (BlueKeep)	4
3.3	Malware e Ransomware Associati	4
4	CWE-190 – Integer Overflow / Underflow	5
4.1	Causa Radice	5
4.2	Caso di Studio: CVE-2006-5270 (Microsoft Malware Protection Engine)	5
5	CWE-134 – Format String Vulnerability	6
5.1	Causa Radice	6
5.2	Caso di Studio: CVE-2019-1579 (PAN-OS GlobalProtect)	6
5.3	Malware e Ransomware Associati	6

6	Architettura della Cifratura Ibrida nei Ransomware Moderni	7
7	Tabella Riassuntiva	7
	Riferimenti	8

1 Metodologia

Ogni sezione di questo report segue una struttura a quattro livelli, coerente con la pratica dei *vulnerability advisory* professionali (CISA, MITRE, vendor security bulletin):

1. **Causa radice (Root Cause)** – descrizione a livello di codice sorgente del pattern che genera la vulnerabilità.
2. **Caso di studio reale** – un CVE ufficiale, verificato su NVD/MITRE/CISA, con descrizione tecnica del meccanismo di exploitation.
3. **Malware/Ransomware associati** – famiglie di software malevolo documentate pubblicamente come utilizzatrici della vulnerabilità.
4. **Mitigazione** – pattern di codice sicuro o strumento di analisi che neutralizza strutturalmente la classe di bug.

2 CWE-787 / CWE-121 / CWE-122 – Buffer Overflow

2.1 Causa Radice

Un buffer overflow si verifica quando un programma scrive oltre i limiti di un buffer allocato, sovrascrivendo memoria adiacente. Nello stack, questo può corrompere l'indirizzo di ritorno di una funzione; nell'heap, può corrompere metadati dell'allocatore o strutture dati adiacenti (incluse VTable in C++).

Listing 1: Pattern vulnerabile tipico (CWE-121, stack buffer overflow)

```

1 void vulnerable_copy(const char* user_input) {
2     char buffer[64];
3     strcpy(buffer, user_input);    // Nessun controllo sulla lunghezza:
4                                   // se user_input > 64 byte, si scrive
5                                   // oltre il buffer, corrompendo lo
6                                   // stack frame (saved RBP, return address)
7 }
```

2.2 Caso di Studio: CVE-2017-0144 (EternalBlue)

Identificativo	CVE-2017-0144
CWE associato	CWE-787 (Out-of-bounds Write), origine CWE-190
Componente	Driver <code>srv.sys</code> , implementazione SMBv1 Windows
CVSS v3	8.1 (High)
Scopritore	NSA (Equation Group), leak via The Shadow Brokers
Data disclosure	14 aprile 2017

Table 1: Scheda tecnica CVE-2017-0144

La vulnerabilità risiede nella funzione `SrvOs2FeaListSizeToNt` del driver kernel `srv.sys`, responsabile della conversione di liste FEA (File Extended Attributes) dal formato OS/2 al formato NT. Un calcolo di dimensione errato (originato da un integer overflow nel calcolo della dimensione del buffer di destinazione) porta all'allocazione di un buffer `NtFeaList` più piccolo del necessario nel pool di memoria kernel non paginato. I dati copiati successivamente eccedono tale buffer, producendo un heap buffer overflow nel contesto kernel, sfruttabile per esecuzione di codice arbitrario con privilegi SYSTEM tramite tecniche di heap spraying.

2.3 Malware e Ransomware Associati

- **WannaCry** (maggio 2017) – ransomware worm che ha utilizzato EternalBlue come vettore di propagazione automatica via rete SMB, infettando oltre 200.000 sistemi in 150 paesi in poche ore, inclusi sistemi ospedalieri del NHS britannico.
- **NotPetya** (giugno 2017) – wiper camuffato da ransomware, ha riutilizzato lo stesso exploit per propagazione laterale in reti aziendali, causando danni stimati in oltre 10 miliardi di dollari a livello globale.

Contromisura / Mitigazione

A livello di codice: validare sempre la dimensione calcolata di un buffer *prima* dell'allocazione, verificando l'assenza di overflow nel calcolo stesso (vedi §4). **A livello di linguaggio:** preferire `std::vector`, `std::array` o `std::span` (C++20) rispetto a buffer C raw con dimensione gestita manualmente. **A livello di build:** compilare sempre con `-fsanitize=address` in fase di sviluppo e con stack canary (`-fstack-protector-strong`) in produzione.

3 CWE-416 – Use-After-Free

3.1 Causa Radice

Un Use-After-Free si verifica quando un programma continua a referenziare un'area di memoria dopo che questa è stata deallocata. Se l'allocatore riassegna quella stessa area a un nuovo oggetto, l'accesso al puntatore *dangling* può leggere o scrivere dati del nuovo oggetto, con conseguenze particolarmente gravi in C++ quando l'oggetto originale è polimorfo (sovrascrittura della VTable, vedi il modulo `uaf_example.cpp` di questo repository per la versione vulnerabile e la relativa patch RAII).

3.2 Caso di Studio: CVE-2019-0708 (BlueKeep)

Identificativo	CVE-2019-0708
CWE associato	CWE-416 (Use After Free)
Componente	Driver <code>termdd.sys</code> , Remote Desktop Services
CVSS v3	9.8 (Critical)
Status CISA KEV	Presente nel catalogo, uso in campagne ransomware confermato
Data disclosure	14 maggio 2019

Table 2: Scheda tecnica CVE-2019-0708

La vulnerabilità, nota come *BlueKeep*, risiede nella gestione del canale virtuale interno `MS_T120` da parte del protocollo RDP. Un messaggio malformato di tipo *Disconnect Provider Indication* causa la liberazione dell'oggetto canale, che resta tuttavia referenziato altrove nel driver. Un successivo pool spray controllato dall'attaccante permette di posizionare dati arbitrari esattamente nella regione di memoria liberata; quando il kernel invoca un gadget di chiamata indiretta attraverso il riferimento ormai dangling, l'attaccante ottiene l'esecuzione di codice con privilegi kernel – da remoto e senza autenticazione.

3.3 Malware e Ransomware Associati

CISA ha classificato CVE-2019-0708 come *Known Exploited Vulnerability* con conferma di utilizzo in campagne ransomware, data la sua natura *wormable* (auto-propagante), paragonabile per

potenziale impatto a EternalBlue. La vulnerabilità è stata inoltre ampiamente integrata in strumenti di cryptomining e botnet che sfruttano endpoint RDP esposti non aggiornati.

Contromisura / Mitigazione

A livello di codice: adottare sistematicamente RAII tramite `std::unique_ptr` per il possesso esclusivo e `std::weak_ptr` per riferimenti non proprietari che richiedono verifica di validità esplicita (`.lock()`) prima dell'uso, come dimostrato nel modulo `uaf_example.cpp`. **A livello di analisi:** AddressSanitizer rileva gli UAF a runtime con stack trace completo di allocazione/deallocazione; Valgrind (`-tool=memcheck`) offre rilevamento complementare in assenza di ricompilazione.

4 CWE-190 – Integer Overflow / Underflow

4.1 Causa Radice

Un integer overflow si verifica quando il risultato di un'operazione aritmetica eccede il range rappresentabile dal tipo di dato, "avvolgendosi" (wraparound) a un valore molto più piccolo o negativo. È particolarmente pericoloso quando il risultato viene usato come dimensione per un'allocazione di memoria: un buffer apparentemente "grande" può tradursi in un'allocazione minuscola, seguita da una scrittura che eccede ampiamente il buffer reale.

Listing 2: Pattern vulnerabile (CWE-190)

```
1 void* allocate_records(size_t count, size_t record_size) {
2     // Se count * record_size supera SIZE_MAX, il prodotto "avvolge"
3     // a un valore piccolo: malloc alloca un buffer minuscolo, ma il
4     // chiamante continuerà a scrivere 'count' record, causando un
5     // heap buffer overflow massivo.
6     return malloc(count * record_size);    // <-- nessun controllo overflow
7 }
```

4.2 Caso di Studio: CVE-2006-5270 (Microsoft Malware Protection Engine)

Identificativo	CVE-2006-5270
CWE associato	CWE-190 (Integer Overflow or Wraparound)
Componente	mpengine.dll (Microsoft Malware Protection Engine)
CVSS v2	9.3 (Critical)
Prodotti affetti	Windows Defender, Windows Live OneCare, Forefront Security

Table 3: Scheda tecnica CVE-2006-5270

Un integer overflow nel motore di scansione antimalware stesso (`mpengine.dll`) permetteva, tramite un file PDF appositamente creato, di causare l'esecuzione di codice arbitrario nel contesto del motore AV – un caso emblematico di come la vulnerabilità possa colpire proprio gli strumenti difensivi, rendendo la vittima potenziale ogni sistema protetto da quel motore. È inoltre utile notare che la stessa classe di difetto (overflow nel calcolo della dimensione di un buffer prima dell'allocazione) è la causa radice della catena EternalBlue descritta in §2: i due casi condividono lo stesso pattern architetturale di errore.

Contromisura / Mitigazione

A livello di codice: utilizzare funzioni di moltiplicazione con rilevamento di overflow esplicito (`__builtin_mul_overflow` in GCC/Clang, oppure verifiche manuali del tipo `if (count > SIZE_MAX / record_size)` prima della moltiplicazione). **A livello di linguaggio:** preferire `std::vector::reserve()` e `std::vector::at()`, che gestiscono internamente la dimensione in modo sicuro e sollevano eccezioni su accesso fuori limite. **A livello di analisi:** UBSan (`-fsanitize=undefined`) rileva integer overflow a runtime durante i test.

5 CWE-134 – Format String Vulnerability

5.1 Causa Radice

Si verifica quando una stringa di formato proveniente da input esterno viene passata direttamente a funzioni come `printf`, `fprintf` o `syslog` senza essere trattata come dato. Specificatori come `%s` permettono la lettura arbitraria dello stack; `%n` permette la scrittura arbitraria in memoria, scrivendo il numero di byte stampati finora all'indirizzo puntato dall'argomento corrispondente.

Listing 3: Pattern vulnerabile (CWE-134)

```

1 void log_user_action(const char* username) {
2     printf(username);           // VULNERABILE: se username contiene "%x%x%n",
3                                 // l'attaccante legge lo stack e può scrivere
4                                 // in memoria arbitraria.
5 }
6
7 void log_user_action_fixed(const char* username) {
8     printf("%s", username);     // CORRETTO: la stringa di formato è
9                                 // letterale e fissa; username è trattato
10                                // sempre come dato, mai come formato.
11 }

```

5.2 Caso di Studio: CVE-2019-1579 (PAN-OS GlobalProtect)

Identificativo	CVE-2019-1579
CWE associato	CWE-134 (Use of Externally-Controlled Format String)
Componente	Portale/Gateway GlobalProtect, Palo Alto Networks PAN-OS
CVSS v3	8.1 (High)
Status CISA KEV	Presente nel catalogo, uso confermato in campagne ransomware
Autenticazione richiesta	Nessuna (pre-auth RCE)

Table 4: Scheda tecnica CVE-2019-1579

Scoperta dai ricercatori Orange Tsai e Meh Chang (DEVCORE), la vulnerabilità risiede nell'interfaccia del portale GlobalProtect SSL VPN: un valore controllato dall'attaccante veniva utilizzato come stringa di formato in una chiamata interna, permettendo – senza alcuna autenticazione – di ottenere prima una lettura di memoria arbitraria e successivamente esecuzione di codice remoto sul gateway stesso, con conseguente possibilità di infiltrare l'intera intranet aziendale raggiungibile tramite quella VPN.

5.3 Malware e Ransomware Associati

CVE-2019-1579 è classificata da CISA come *Known Exploited Vulnerability* con **uso confermato in campagne ransomware**: gateway VPN aziendali non aggiornati sono stati storicamente

uno dei vettori di accesso iniziale preferiti dagli affiliati ransomware (pattern condiviso con altre vulnerabilità VPN enterprise), poiché un singolo gateway compromesso apre l'accesso all'intera rete interna per la successiva fase di movimento laterale e deployment del payload di cifratura.

Contromisura / Mitigazione

A livello di codice: non passare *mai* input esterno come primo argomento di una funzione printf-family; usare sempre `printf("%s", input)`. **A livello di compilatore:** abilitare `-Wformat -Wformat-security -Werror=format-security`, che trasforma l'uso di stringhe di formato non letterali in un errore di compilazione. **A livello di linguaggio:** in C++20, preferire `std::format` con stringhe di formato `constexpr`, verificate a compile-time.

6 Architettura della Cifratura Ibrida nei Ransomware Moderni

A differenza delle sezioni precedenti, questa non descrive una vulnerabilità ma un pattern *architetturale* ampiamente documentato nella letteratura di sicurezza (inclusi i report tecnici post-incidente su WannaCry e famiglie successive), utile per comprendere perché la cifratura ibrida sia lo standard de facto nel ransomware.

- **Cifratura simmetrica (AES-256)** dei file della vittima: veloce (centinaia di MB/s), adatta a cifrare grandi volumi di dati in tempi brevi.
- **Cifratura asimmetrica (RSA-2048)** della *sola* chiave di sessione AES: la chiave pubblica dell'attaccante è tipicamente incorporata nel binario, mentre la corrispondente chiave privata resta sul server dell'attaccante, resa disponibile solo dietro pagamento del riscatto.
- **Conseguenza difensiva fondamentale:** senza la chiave privata RSA, la decifratura è computazionalmente infattibile anche conoscendo l'algoritmo esatto – motivo per cui il recupero dei file richiede quasi sempre backup offline, non la "rottura" della cifratura stessa.

Il modulo `hybrid_crypto_demo.cpp` di questo repository implementa questo schema in forma isolata e didattica (OpenSSL, AES-256-GCM + RSA-2048-OAEP) su dati di test locali, senza alcuna logica di enumerazione del filesystem, persistenza o comunicazione di rete.

7 Tabella Riassuntiva

CVE	CWE	Componente	Malware/Ransomware	VSS
CVE-2017-0144	CWE-787	SMBv1 <code>srv.sys</code>	WannaCry, NotPetya	8.1
CVE-2019-0708	CWE-416	RDP <code>termdd.sys</code>	Campagne ransomware, worm RDP	9.8
CVE-2006-5270	CWE-190	<code>mpengine.dll</code> (AV engine)	RCE via PDF malevolo	9.3
CVE-2019-1579	CWE-134	PAN-OS GlobalProtect	Campagne ransomware (accesso iniziale)	8.1

Table 5: Riepilogo dei CVE analizzati in questo report

Riferimenti

References

- [1] NIST National Vulnerability Database, *CVE-2017-0144 Detail*, <https://nvd.nist.gov/vuln/detail/CVE-2017-0144>
- [2] NIST National Vulnerability Database, *CVE-2019-0708 Detail*, <https://nvd.nist.gov/vuln/detail/CVE-2019-0708>
- [3] NIST National Vulnerability Database, *CVE-2006-5270 Detail*, <https://nvd.nist.gov/vuln/detail/CVE-2006-5270>
- [4] NIST National Vulnerability Database, *CVE-2019-1579 Detail*, <https://nvd.nist.gov/vuln/detail/CVE-2019-1579>
- [5] CISA, *Known Exploited Vulnerabilities Catalog*, <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [6] MITRE, *Common Weakness Enumeration (CWE) List*, <https://cwe.mitre.org>
- [7] Unit 42, Palo Alto Networks, *Exploitation of Windows RDP Vulnerability CVE-2019-0708 (BlueKeep)*, <https://unit42.paloaltonetworks.com/cve-2019-0708-bluekeep/>